

The Federal Information Processing Standard Publication 140-2, (FIPS PUB 140-2), is a U.S. government computer security standard used to approve cryptographic modules. The title is Security Requirements for Cryptographic Modules. Initial publication was on May 25, 2001, and was last updated December 3, 2002.

Its successor, FIPS 140-3, was approved on March 22, 2019, and became effective on September 22, 2019. FIPS 140-3 testing began on September 22, 2020, and the first FIPS 140-3 validation certificates were issued in December 2022. FIPS 140-2 testing was still available until September 21, 2021 (later changed for applications already in progress to April 1, 2022), creating an overlapping transition period of more than one year. FIPS 140-2 test reports that remain in the CMVP queue will still be granted validations after that date, but all FIPS 140-2 validations will be moved to the Historical List on September 21, 2026 regardless of their actual final validation date.

Purpose

The National Institute of Standards and Technology (NIST) issued the FIPS 140 Publication Series to coordinate the requirements and standards for cryptography modules that include both hardware and software components. Protection of a cryptographic module within a security system is necessary to maintain the confidentiality and integrity of the information protected by the module. This standard specifies the security requirements that will be satisfied by a cryptographic module. The standard provides four increasing qualitative levels of security intended to cover a wide range of potential applications and environments. The security requirements cover areas related to the secure design and implementation of a cryptographic module. These areas include cryptographic module specification; cryptographic module ports and interfaces; roles, services, and authentication; finite state model; physical security; operational environment; cryptographic key management; electromagnetic interference/electromagnetic compatibility (EMI/EMC); self-tests; design assurance; and

mitigation of other attacks.

Federal agencies and departments can validate that the module in use is covered by an existing FIPS 140-1 or FIPS 140-2 certificate that specifies the exact module name, hardware, software, firmware, and/or applet version numbers. The cryptographic modules are produced by the private sector or open source communities for use by the U.S. government and other regulated industries (such as financial and health-care institutions) that collect, store, transfer, share and disseminate sensitive but unclassified (SBU) information. A commercial cryptographic module is also commonly referred to as a hardware security module (HSM).

Security levels

FIPS 140-2 defines four levels of security, simply named "Level 1" to "Level 4". It does not specify in detail what level of security is required by any particular application.

Level 1

Security Level 1 provides the lowest level of security. Basic security requirements are specified for a cryptographic module (e.g., at least one Approved algorithm or Approved security function shall be used). No specific physical security mechanisms are required in a Security Level 1 cryptographic module beyond the basic requirement for production-grade components. An example of a Security Level 1 cryptographic module is a personal computer (PC) encryption board.

Level 2

Security Level 2 improves upon the physical security mechanisms of a Security Level 1 cryptographic module by requiring features that show evidence of tampering, including tamper-evident coatings or seals that must be broken to attain physical access to the plaintext cryptographic keys and critical security parameters (CSPs) within the module, or pick-resistant

locks on covers or doors to protect against unauthorized physical access.

Level 3

In addition to the tamper-evident physical security mechanisms required at Security Level 2, Security Level 3 attempts to prevent the intruder from gaining access to CSPs held within the cryptographic module. Physical security mechanisms required at Security Level 3 are intended to have a high probability of detecting and responding to attempts at physical access, use or modification of the cryptographic module. The physical security mechanisms may include the use of strong enclosures and tamper-detection/response circuitry that zeroes all plaintext CSPs when the removable covers/doors of the cryptographic module are opened.

Level 4

Security Level 4 provides the highest level of security. At this security level, the physical security mechanisms provide a complete envelope of protection around the cryptographic module with the intent of detecting and responding to all unauthorized attempts at physical access. Penetration of the cryptographic module enclosure from any direction has a very high probability of being detected, resulting in the immediate deletion of all plaintext CSPs.

Security Level 4 cryptographic modules are useful for operation in physically unprotected environments. Security Level 4 also protects a cryptographic module against a security compromise due to environmental conditions or fluctuations outside of the module's normal operating ranges for voltage and temperature. Intentional excursions beyond the normal operating ranges may be used by an attacker to thwart a cryptographic module's defenses. A cryptographic module is required to either include special environmental protection features designed to detect fluctuations and delete CSPs, or to undergo rigorous environmental failure testing to provide a reasonable assurance that the module will not be affected by fluctuations outside of the normal operating range in a manner that can compromise the security of the

module.

Operating platform

For Levels 2 and higher, the operating platform upon which the validation is applicable is also listed. Vendors do not always maintain their baseline validations.

Cryptographic Module Validation Program

FIPS 140-2 establishes the Cryptographic Module Validation Program (CMVP) as a joint effort by the NIST and the Communications Security Establishment (CSE) for the Government of Canada

Security programs overseen by NIST and CSE focus on working with government and industry to establish more secure systems and networks by developing, managing and promoting security assessment tools, techniques, services, and supporting programs for testing, evaluation and validation; and addresses such areas as: development and maintenance of security metrics, security evaluation criteria and evaluation methodologies, tests and test methods; security-specific criteria for laboratory accreditation; guidance on the use of evaluated and tested products; research to address assurance methods and system-wide security and assessment methodologies; security protocol validation activities; and appropriate coordination with assessment-related activities of voluntary industry standards bodies and other assessment regimes.

FIPS 140-2 testing in this program

The FIPS 140-2 standard is an information technology security approval program for cryptographic modules produced by private sector vendors who seek to have their products certified for use in government departments and regulated industries (such as financial and health-care institutions) that collect, store, transfer, share and disseminate sensitive but

unclassified (SBU) information.

Tamper evident FIPS 140-2 security labels are utilized to deter and detect tampering of modules.

Laboratories doing the testing

All of the tests under the CMVP are handled by third-party laboratories that are accredited as Cryptographic Module Testing laboratories by the National Voluntary Laboratory Accreditation Program (NVLAP). Vendors interested in validation testing may select any of the twenty-one accredited labs.

NVLAP accredited Cryptographic Modules Testing laboratories perform validation testing of cryptographic modules. Cryptographic modules are tested against requirements found in FIPS PUB 140-2, Security Requirements for Cryptographic Modules. Security requirements cover 11 areas related to the design and implementation of a cryptographic module. Within most areas, a cryptographic module receives a security level rating (1-4, from lowest to highest), depending on what requirements are met. For other areas that do not provide for different levels of security, a cryptographic module receives a rating that reflects fulfillment of all of the requirements for that area.

Validation

An overall rating is issued for the cryptographic module, which indicates:

the minimum of the independent ratings received in the areas with levels, and
the fulfillment of all the requirements in the other areas.

On a vendor's validation certificate, individual ratings are listed, as well as the overall rating.

NIST maintains validation lists for all of its cryptographic standards testing programs (past and present). All of these lists are updated as new modules/implementations receive validation

certificates from NIST and CSE. Items on the FIPS 140-1 and FIPS 140-2 validation list reference validated algorithm implementations that appear on the algorithm validation lists.

Compliance

In addition to using a valid cryptographic module, encryption solutions are required to use cipher suites with approved algorithms or security functions established by the FIPS 140-2 Annex A to be considered FIPS 140-2 compliant.

Annexes

FIPS PUB 140-2 Annexes:

Annex A: Approved Security Functions (Draft October 12, 2021)

Annex B: Approved Protection Profiles (Draft June 10, 2019)

Annex C: Approved Random Number Generators (Draft October 12, 2021)

Annex D: Approved Key Establishment Techniques (Draft October 12, 2021)

Criticism

Steven Marquess posted in 2009 that FIPS 140-2 validation could lead to incentives to keep vulnerabilities and other defects hidden. CMVP can decertify software in which vulnerabilities are found, but it can take a year to re-certify software if defects are found, so companies can be left without a certified product to ship. As an example, Marquess mentions a vulnerability that was found, publicised, and fixed in the FIPS-certified open-source derivative of OpenSSL, with the publication meaning that the OpenSSL derivative was decertified. This decertification hurt companies relying on the OpenSSL-derivative's FIPS certification. By contrast, companies that had renamed and certified a copy of the open-source OpenSSL derivative were not decertified, even though they were basically identical, and did not fix the vulnerability.

Marquess therefore argues that the FIPS process inadvertently encourages hiding software's origins, to de-associate it from defects since found in the original, while potentially leaving the certified copy vulnerable.

In recent years, CMVP has taken steps to avoid the situation described by Marquess, moving validations to the Historical List based on the algorithms and functions contained in the module, rather than based on the provenance.

See also

Common Criteria

Crypto-shredding

FIPS 140

FIPS 140-3

Tamperproofing

References

External links

"FIPS PUB 140-2" (PDF). NIST. December 3, 2002. Retrieved March 31, 2017.

"FIPS PUB 140-2 - Effective 15-Nov-2001". NIST. May 1, 2013. Retrieved May 18, 2013.

"FIPS Validation". Mozilla. November 16, 2011. Retrieved May 18, 2013.

"OpenSSL and FIPS 140-2". OpenSSL. February 21, 2013. Retrieved May 18, 2013.

"OpenFIPS Project". axiomasec.com. Retrieved May 18, 2013.

"General Flow FIPS 140-2 Validation Testing". jtsec. November 16, 2011. Retrieved March 24, 2018.